

Security Policy — ADRION 369

Bezpieczeństwo systemu jest współodpowiedzialnością całej społeczności.
Każde zgłoszenie jest traktowane jako wkład w realizację Prawa G6 (Nonmaleficence).

Wspierane Wersje

Wersja	Status	Wsparcie bezpieczeństwa
<code>main</code> (dev)	 Aktywny rozwój	 Pełne
<code>v0.x</code> (prototype)	 Planowana	 Pełne po wydaniu
Wcześniejsze	—	 Brak

Zgłaszanie Luk Bezpieczeństwa

NIE zgłaszaj luk przez publiczne Issues

Publiczne zgłoszenie przed naprawą naraża użytkowników systemu.
Narusza to Prawo G6 (Nonmaleficence) — fundamentalny zakaz szkodenia.

Użyj jednej z poniższych ścieżek

Opcja 1 — GitHub Private Security Advisory (zalecane):

Repozytorium → Security → Advisories → New draft security advisory

Opcja 2 — Email:

security@adrion369.dev
Temat: [ADRION-SEC] Krótki opis luki

Opcja 3 — Szyfrowany kontakt (PGP):

Klucz publiczny: /docs/security/pgp-key.asc
Fingerprint: [do uzupełnienia przy publikacji]

Co Zawrzeć w Zgłoszeniu

Aby przyspieszyć analizę, podaj:

- 1. **ID wektora ataku** (jeśli znany z docs/THREAT_MODEL.md), np. A-03)
- 2. **Opis luki** — co, gdzie, w jaki sposób
- 3. **Kroki reprodukcji** — minimalne, powtarzalne
- 4. **Wpływ** — które Prawo Strażnika (G1-G9) jest naruszone i w jaki sposób
- 5. **Środowisko** — wersja, OS, konfiguracja
- 6. **Propozycja mitigacji** — opcjonalnie, ale bardzo ceniona

Przykład dobrego zgłoszenia

```
Wektor: A-03 (EBDI Poisoning) – nowy wariant
Opis: Możliwe przesunięcie baseline PAD przez <X> zapytań
      o specyficznnej strukturze lingwistycznej.
Reprodukcja:
  1. Wyślij serię N zapytań z wzorcem [...]
  2. Obserwuj drift wektora PAD w Grafana dashboard
  3. Po N+1 zapytaniu system nie wykrywa anomalii [...]
Wpływ: Naruszenie G3 (Rhythm) i G6 (Nonmaleficence)
Środowisko: main@a7f3e4c, Python 3.11, Docker Compose
```

Proces Odpowiedzi

Krok	Czas	Działanie
Potwierdzenie odbioru	< 48h	Potwierdzamy otrzymanie zgłoszenia
Wstępna ocena	< 7 dni	Ocena krytyczności wg macierzy ryzyka THREAT_MODEL
Aktualizacja statusu	Co 7 dni	Informujemy o postępach do czasu naprawy
Naprawa (krytyczna)	< 30 dni	Wektory 🔴 z THREAT_MODEL
Naprawa (wysoka)	< 90 dni	Wektory 🟡 z THREAT_MODEL
Publiczne ujawnienie	Po naprawie	Coordinated disclosure — ustalamy wspólnie

Zakres Programu

W zakresie (in-scope)

- Wszystkie wektory ataku A-01-A-12 z docs/THREAT_MODEL.md
- Nowe wektory nie ujęte w THREAT_MODEL
- Bypass mechanizmów Guardian (G1-G9)
- Manipulacja wektorem PAD (EBDI Poisoning)
- Naruszenie integralności Genesis Record
- Eskalacja uprawnień w Agent Swarm
- Wstrzyknięcia do SAFE-MCP Protocol

Poza zakresem (out-of-scope)

- Ataki na infrastrukturę hosta (odpowiedzialność operatora)
- Ataki na zewnętrzne modele LLM (OpenAI, Anthropic)
- Social engineering wobec maintainerów projektu
- Ataki wymagające fizycznego dostępu do serwera
- Znane luki w zależnościach bez PoC dla ADRION

Klasyfikacja Krytyczności

Używamy klasyfikacji spójnej z docs/THREAT_MODEL.md:

Poziom	Opis	Przykład	Czas naprawy
Krytyczny	Całkowite ominięcie G6 lub Genesis Record	A-03 EBDI Poisoning	< 30 dni
Wysoki	Bypass pojedynczego Guardian	A-01 Fałszywy rozkaz	< 60 dni
Średni	Ograniczone naruszenie, wymaga uprawnień	A-07 Prompt injection	< 90 dni
Niski	Minimalne ryzyko, brak bezpośredniego wpływu	A-08 Timing attack	< 180 dni

Nagrody i Podziękowania

Projekt jest w fazie wczesnego rozwoju (TRL 2/9) — nie prowadzimy formalnego programu Bug Bounty.

Oferujemy:

- Wpis do `CHANGELOG.md` z podziękowaniem (opcjonalnie anonimowo)
 - Credit w Security Advisory po publicznym ujawnieniu
 - Priorytetowy dostęp do dyskusji architektonicznych
-

Polityka Ujawniania (Coordinated Disclosure)

1. Zgłaszający powiadamia nas prywatnie
2. Ustalamy wspólnie termin publicznego ujawnienia (standardowo 90 dni)
3. Przygotowujemy patch i Security Advisory
4. Jednoczesna publikacja naprawy i ujawnienia
5. Wpis do Genesis Record z pełną dokumentacją (G4 + G5)

Jeśli nie odpowiemy w ciągu **14 dni** od zgłoszenia — masz prawo ujawnić lukę publicznie.

Aktualizacja Modelu Zagrożeń

Każda potwierdzona luka bezpieczeństwa skutkuje:

1. Aktualizacją `docs/THREAT_MODEL.md` o nowy wektor
 2. Wpisem w Genesis Record z uzasadnieniem (G4)
 3. Przeglądem powiązanych Guardianów (G1-G9)
 4. Aktualizacją testów regresyjnych
-

Dziękujemy za pomoc w budowaniu bezpiecznego systemu zgodnego z Prawem G6 (Nonmaleficence).

Każde odpowiedzialne zgłoszenie to wkład w realizację Superior Moral Code.